C28 · TOPIC 3 · LAB 6 · 40 MIN · LO3 · A1, A2

Create an AI Incident Report: The Leak From Three Months Ago

AI Agent Security · Version 2.0 · 7 November 2026

Traces say an agent uploaded 1,284 members to an outside address at 02:17 on 7 August. Work out how, and write the report the regulator would read.

Your mission

On 7 Aug 2026 Kopi Kaki's supplier-inbox agent, Mia, read a fake supplier email, then uploaded the loyalty file to an outside address. Nobody noticed until members reported phishing SMSes on 12 Aug. Today is 7 Nov 2026. You have 146 trace events, the helpdesk tickets and the email. Everything is fictional.

You will hand in

- outputs/ai-incident-report.docx, with facts you verified against the traces
- A check_report.py result
- Your screenshot for your lab record

Copy prompts in one click: https://tertiarycourses.github.io/C28-AI-Agent-Security/prompts/index.html#lab-06, or open `prompts/index.html` in the course folder. It also works offline.

Before you start

- Lab 2 finished
- Use a stronger model if you have one: there are 146 events to read
- All names, addresses and filings are fictional

What is in this folder

File	What it is
`data/agent-traces.jsonl`	146 mock trace events, 3 to 15 August 2026.
`data/helpdesk-tickets.csv`	The tickets that revealed the leak.
`data/incident-brief.txt`	Your assignment.
`data/phishing-email.txt`	The fake supplier email.
`scripts/check_report.py`	Checks your report states what the traces and the PDPA demand.
`scripts/trace_query.py`	Reads the traces yourself, so you can check the AI.

You do not write code. Your agent runs the scripts, and you read the result.

Steps

1. Read the traces yourself first (8 min)

In Hermes Desktop start a New session, click + (left of Ask anything) → Folder… and choose this lab's folder.

PROMPT · PASTE INTO HERMES DESKTOP

```
Read data/incident-brief.txt. Then run these two commands and show me the output
without interpreting it yet:
python3 scripts/trace_query.py data/agent-traces.jsonl
python3 scripts/trace_query.py data/agent-traces.jsonl s-0807-0210
```

✓ You should see: An overview, then one session: a supplier email read, the loyalty file read, then an http_post to audit-share.example at 02:17.

2. Paste the report prompt (10 min)

PROMPT · PASTE INTO SAME SESSION

```
You are an incident analyst for Kopi Kaki Co. Using ONLY data/agent-traces.jsonl,
data/helpdesk-tickets.csv, data/phishing-email.txt and data/incident-brief.txt,
write an AI Incident Report as outputs/ai-incident-report.docx with these sections:

1. Executive summary, in five lines
2. Incident timeline: a table of time, event, source event or ticket
3. What happened: how the agent was manipulated, quoting the exact planted
instruction
4. Root cause: technical, process and human factors
5. Impact: individuals affected, data types, harm to them, harm to the company
6. C.A.R.E. response: Contain, Assess, Report, Evaluate, with what was done and
when
7. PDPA analysis: is it notifiable, and why? When did the 3 calendar days to notify
PDPC start? Was the deadline met?
8. Five principles: what failed under Data Control, Permission Control, Human in
the Loop, Traceability and Right-Sized Models, and one fix for each
9. Actions: owner, due date, how we will know it is done
10. Open questions: anything the evidence cannot answer

For every fact, cite the session id or ticket number. Do not invent facts. If the
evidence does not show something, say so in section 10. Install any library you
need. Then run: python3 scripts/check_report.py outputs/ai-incident-report.docx and
show me the result.
```

✓ You should see: A .docx file and a PASS or list of gaps.

3. Verify it against the traces (12 min)

Be the sceptic. Check at least five facts against the raw output from step 1: the leak time, the record count, the address, the determination date and the PDPC filing date. Hunt for a sentence that goes further than the evidence, such as claiming who sent the phishing SMS. Traces do not prove that. A strong model may already mark it as unproven; then find what it still got wrong, left out or worded too confidently, and check that its timeline matches. Note one specific finding for your your notes answer.

PROMPT · PASTE INTO SAME SESSION

```
Correct the report: [describe what you found]. Mark anything the traces do not
prove as unconfirmed. Then run check_report.py again and show me the result.
```

✓ You should see: check_report.py says READY for human review, and you have your own list of findings.

4. Make the management call (5 min)

Read sections 7 and 8. In one sentence each: was the 3-day deadline met, which principle would have stopped this first, and who is accountable? The AI drafted the report, but a person answers for it.

✓ You should see: Three sentences you could defend to the CEO.

5. Screenshot for your lab record (5 min)

Capture the report's timeline and root cause, on one screen if you can.

✓ You should see: your lab record incident screenshot is saved.

> 📸 **Screenshot for your lab record. Keep it in your lab record.**

Check your work

- □ Leak time, 02:17 on 7 Aug 2026, and the address match the traces
- □ 1,284 individuals and the data types are stated
- □ The report separates determination (14 Aug) from discovery (12 Aug)
- □ Unproven claims are marked unconfirmed

Checkpoint: A report with the verified timeline, root cause, PDPA analysis, C.A.R.E. and five-principle fixes, with a PASS from check_report.py. your lab record screenshot saved.

If something goes wrong

What you see	What to do
Agent says it cannot find the session	Ask it to run trace_query.py with the session id, and read the output.

The report is thin	Ask for each section separately, starting with the timeline.
It states who the attacker was	The evidence does not show that. Tell it to move the claim to Open questions.

Finished early?

Write the three-line notification to affected members. Is it honest about what you know and do not know? Would you be reassured or more worried if you received it?

All company data in these labs is fictional and generated for training: Kopi Kaki Co., its people, members, NRIC numbers, tickets and traces.
Part of the course AI Agent Security (C28) · © 2026 Tertiary Infotech Academy Pte Ltd · UEN: 201200696W · www.tertiarycourses.com.sg